Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

Group Details

- COLLEGE NAME : ADITHYA COLLEGE OF ARTS AND SCIENCE
- TEAM ID : SWTID- 2026-1097

- TEAM LEADER : Madhumitha K M
  CONTACT :9095952864

- TEAM MEMBER :Jayasruthi S
  CONTACT : 6379496437

- TEAM MEMBER : Majunu V
  CONTACT : 6381089057

- TEAM MEMBER : Sheshadri P
  CONTACT : 9003322414

- TEAM MEMBER : Suraj Kumar Mishra
  CONTACT : 9566953114

Project details

Title : Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

In response to the evolving threat landscape and the dissolution of the traditional network perimeter, this project initiates a fundamental shift in our security architecture. We will be decommissioning our legacy VPN infrastructure, which relies on an outdated castle-and-moat model that grants excessive network access and is vulnerable to lateral threat movement. To replace it, we are adopting a cloud-native, Zero Trust approach powered by Zscaler.

This new architecture is built on the principle of "never trust, always verify," ensuring that users are connected to applications, not to the network. By making applications invisible to the internet and establishing direct, secure user-to-app connections, we will drastically reduce our attack surface. This modern solution eliminates the risk of lateral movement, as threats can no longer traverse a flat network. Furthermore, it provides a superior, high-performance experience for our hybrid workforce, decoupling security from data center backhauling. The transition to Zscaler will not only bolster our security posture but also enhance agility and reduce the operational overhead associated with managing legacy hardware. This initiative is a critical step in future-proofing our organization against sophisticated cyber threats.

Abstract : This project details the strategic migration from a legacy Virtual Private Network (VPN) infrastructure to a cloud-native Zero Trust Network Access (ZTNA) solution provided by Zscaler. The primary driver for this initiative is the fundamental inadequacy of traditional VPNs in the modern threat landscape. Legacy architectures operate on a "connect first, verify later" model, granting users broad access to the corporate network and, consequently, creating a significant risk of lateral movement by malicious actors. This expansive attack surface, combined with the operational overhead of managing physical appliances and the poor user experience associated with hair-pinned traffic, renders the existing model both insecure and inefficient for today's hybrid workforce.

The proposed solution leverages the Zscaler Zero Trust Exchange, a global, cloud native platform that shifts connectivity from a network-centric to an identity and applicationcentric model. By making corporate applications invisible to the internet and establishing direct, secure connections between verified users and specific applications, the new architecture eliminates the concept of network-based privileges. This approach ensures that users connect to the applications they need, not the underlying network, thereby completely neutralizing the threat of lateral movement. Furthermore, it improves performance by steering traffic directly to Zscaler’s edge nodes, optimizing the user experience regardless of their location.

The expected outcomes of this modernization project are multifaceted. We anticipate a drastic reduction in the organization's attack surface and the complete elimination of lateral movement risks. This will be coupled with a simplified, scalable security posture managed from a unified cloud console, reducing operational costs and complexity. Ultimately, this transition will not only fortify our cyber defenses against sophisticated threats but also enable a secure, high performance, and agile work environment, futureproofing the organization's security architecture.

Use case scenarios:

Scenario 1: Third-Party Vendor Access to Finance Application

An external auditor needs temporary access to the university's finance application for end-of year reconciliation. Instead of provisioning a VPN account, ZPA grants timebound, application specific access. The vendor authenticates via identity provider and is micro-segmented away from all other internal resources.

Output:

• User identity verified (External_Auditor_Group)

• Time-bound access policy enforced (7-day validity)

• Connection restricted to Finance Application only

• No lateral movement possible to other systems

Scenario 2: Research Assistant Access to High-Performance Computing Cluster

A graduate student requires SSH access to an on-premises research computing cluster to run data analysis scripts. Using ZPA, they connect directly to the cluster without exposing SSH ports to the internet or requiring a full network-level VPN tunnel.

Output:

• User identity verified (Research_Assistant_Group)

• Protocol-specific access granted (SSH only)

• Direct micro-tunnel established to HPC Cluster

• All other network segments remain inaccessible

Scenario 3: Administrative Staff Access to Internal File Server

An administrative assistant working from a campus satellite office needs to access a sensitive file server containing student records. ZPA verifies their device compliance and routes them exclusively to the file server application, with all traffic inspected inline for data loss prevention.

Output:

• User identity verified (Admin_Staff_Group)

• Device posture compliant (Disk encryption enabled, patch level current)

• Granular file access policies enforced (Read/Write permissions)

• Data Loss Prevention (DLP) policies active

Scenario 4: IT Administrator Secure Access to Server Management Interfaces

A systems administrator requires RDP access to manage critical Windows servers in the data center. Using ZPA, they connect directly to the target servers without exposing RDP to the internet, while all administrative sessions are recorded for audit compliance.

Output:

• User identity verified (IT_Admin_Group)

• Privileged access workflow triggered (Approval required)

• Session recording and monitoring active

• Micro-tunnel established to specific server IP and port only

Scenario 5: Visiting Professor Access to Library Resources

A visiting professor from a partner institution needs temporary access to digitized archives stored on an internal library application server. ZPA provides just-in-time access without placing the visiting scholar on the internal network, ensuring separation from administrative systems.

Output:

• User identity verified (Visiting_Faculty_Group)

• Just-in-time access provisioned (8-hour session limit)

• Connection restricted to Library Application Server

• Full network segmentation maintained

Stage 1

Title of the Project : OWASP to 10

Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

Overview :

This project is a strategic initiative to fundamentally transform the organization's remote access and network security architecture by decommissioning the existing legacy Virtual Private Network (VPN) infrastructure and replacing it with a cloud-native Zero Trust solution from Zscaler. The current VPN model, based on a perimeter-centric "castle-and-moat" approach, inherently trusts users once they are connected, granting them broad access to the internal network. This expansive access creates a significant attack surface and leaves the organization vulnerable to lateral movement, where a single compromised credential can lead to a widespread breach. The operational challenges of managing, scaling, and patching legacy VPN appliances, coupled with the poor user experience of backhauled traffic, further underscore the urgent need for modernization. This project directly addresses these critical security and operational deficiencies. The core of the new architecture is Zscaler Private Access (ZPA), which operates on a Zero Trust principle of "never trust, always verify" and "connect the user to applications, not the network." By making internal applications completely invisible to the internet and the public DNS, ZPA eliminates the attack surface associated with exposed ports and IP addresses. When a user requests access, ZPA verifies their identity and context—through integrations with identity providers like Azure AD and device posture checks—before establishing a secure, encrypted micro-tunnel. Crucially, this tunnel connects the user only to the specific application they are authorized to use, not to the underlying network. This effectively renders the network invisible to the end-user and eliminates any possibility of lateral movement, as threat actors cannot scan, discover, or pivot to other internal resources.

The anticipated outcomes of this modernization are profound and multi-faceted. The organization will achieve a drastically reduced attack surface and a complete eradication of lateral movement risks, significantly strengthening its security posture against advanced cyber threats. Operationally, the shift to a cloud-native, globally distributed edge removes the need for traffic hair-pinning, thereby optimizing performance and user experience for a hybrid workforce. This transition also simplifies IT operations by replacing complex, hardware-dependent VPN infrastructure with a unified, scalable, and agile cloud management console. Ultimately, this project will not only fortify the organization's defenses but also create a secure, high-performance, and future-ready access framework that supports evolving business needs.

This expansive access creates a significant attack surface and leaves the organization vulnerable to lateral movement, where a single compromised credential can lead to a widespread breach. The operational challenges of managing, scaling, and patching legacy

VPN appliances, coupled with the poor user experience of backhauled traffic, further underscore the urgent need for modernization. This project directly addresses these critical security and operational deficiencies. The core of the new architecture is Zscaler Private Access (ZPA), which operates on a Zero Trust principle of "never trust, always verify" and "connect the user to applications, not the network." By making internal applications completely invisible to the internet and the public DNS, ZPA eliminates the attack surface associated with exposed ports and IP addresses. When a user requests access, ZPA verifies their identity and context—through integrations with identity providers like Azure AD and device posture checks—before establishing a secure, encrypted micro-tunnel. Crucially, this tunnel connects the user only to the specific application they are authorized to use, not to the underlying network. This effectively renders the network invisible to the end-user and eliminates any possibility of lateral movement, as threat actors cannot scan, discover, or pivot to other internal resources.

List of Vulnerability Table :

s.no	Vulnerability name	CWE/CVE no.
1	Absolute Path Traversal	CWE-36
2	Sensitive Cookie in HTTPS Session Without 'Secure' Attribute	CWE-614
3	Use of Unmaintained Third Party Components	CWE-1104

Report :

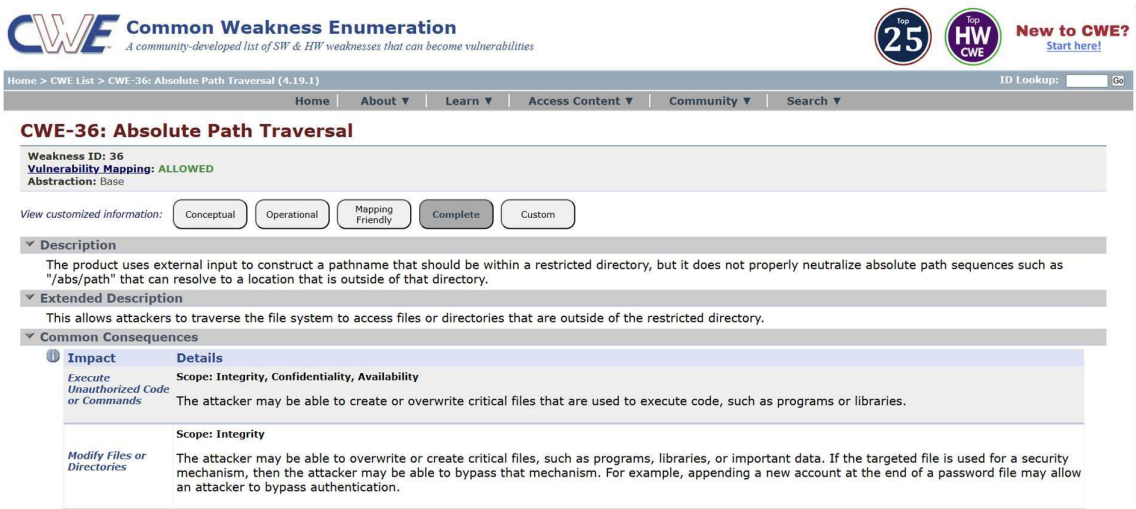
1) vulnerability Name : Absolute Path Traversal

CWE/CVE Number : CWE-36

OWASP Category : A01:2025 Broken Access Control

Description : Access control enforces policy such that users cannot act outside of their intended permissions. Failures typically lead to unauthorized information disclosure, modification or destruction of all data, or performing a business function outside the user's limits.

Business Impact : Absolute Path Traversal (CWE-36) exposes sensitive data like credentials and code, causing breaches, system downtime, and corruption. Businesses suffer regulatory fines, legal costs, and reputational damage from lost trust. Critical sectors face multimillion-dollar losses and disruptions.



Common Weakness Enumeration
A community-developed list of SW & HW weaknesses that can become vulnerabilities

Home > CWE List > CWE-36: Absolute Path Traversal (4.19.1)

Home | About ▼ | Learn ▼ | Access Content ▼ | Community ▼ | Search ▼

CWE-36: Absolute Path Traversal

Weakness ID: 36
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product uses external input to construct a pathname that should be within a restricted directory, but it does not properly neutralize absolute path sequences such as "/abs/path" that can resolve to a location that is outside of that directory.

Extended Description

This allows attackers to traverse the file system to access files or directories that are outside of the restricted directory.

Common Consequences

Impact	Details
Execute Unauthorized Code or Commands	Scope: Integrity, Confidentiality, Availability The attacker may be able to create or overwrite critical files that are used to execute code, such as programs or libraries.
Modify Files or Directories	Scope: Integrity The attacker may be able to overwrite or create critical files, such as programs, libraries, or important data. If the targeted file is used for a security mechanism, then the attacker may be able to bypass that mechanism. For example, appending a new account at the end of a password file may allow an attacker to bypass authentication.

Recommendation:

- Validate and Sanitize Inputs : Strictly validate user-supplied inputs for file paths, rejecting or sanitizing absolute paths and traversal sequences like ".." or "//". Block special characters such as "..", "/" to prevent bypassing restrictions.
- Canonicalize Paths : Normalize all file paths to their canonical form using language-specific functions before processing to eliminate traversal tricks like multiple "../".
- Use Path Whitelisting : Maintain an allowlist of permitted filenames, directories, or extensions, and map user inputs to internal identifiers instead of directly constructing paths from external data.
- Enforce Restricted Directories : Construct paths by appending validated inputs only to a secure base directory, ensuring operations stay within intended boundaries via chroot or similar sandboxing.
- Deploy Web Application Firewall (WAF) : Implement a WAF to detect and block path traversal attempts in real-time, providing defense-in-depth even if code fixes are pending.

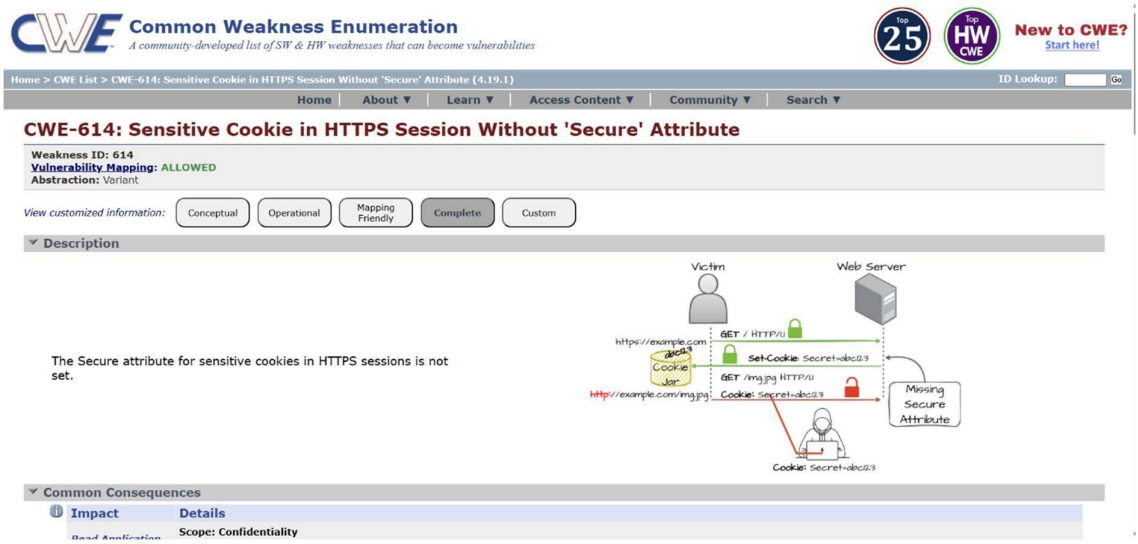
2) Vulnerability Name : Sensitive Cookie in HTTPS Session Without 'Secure' Attribute

CWE/CVE Number : CWE-614

OWASP Category : A02:2025 Security Misconfiguration

Description : Security misconfiguration is when a system, application, or cloud service is set up incorrectly from a security perspective, creating vulnerabilities.

Business Impact : Exposes session cookies to HTTP interception, allowing session hijacking and data breaches. Leads to financial losses, regulatory fines (e.g., GDPR), and reputational harm.



Recommendation:

- Set Secure Attribute : Configure all sensitive cookies (e.g., session IDs) with the Secure flag to ensure they are only transmitted over HTTPS connections, preventing exposure on HTTP.
- Enforce HTTPS Everywhere: Redirect all HTTP traffic to HTTPS and implement HSTS (HTTP Strict Transport Security) to mandate secure connections application-wide.
- Update Framework Config: In web frameworks, enable secure cookie settings by default in production (e.g., session.cookie_secure = true in PHP) and verify via tools like browser dev tools.

- Audit Custom Cookies: Manually add Secure to any application-set cookies containing sensitive data, and apply HttpOnly for additional protection against XSS.

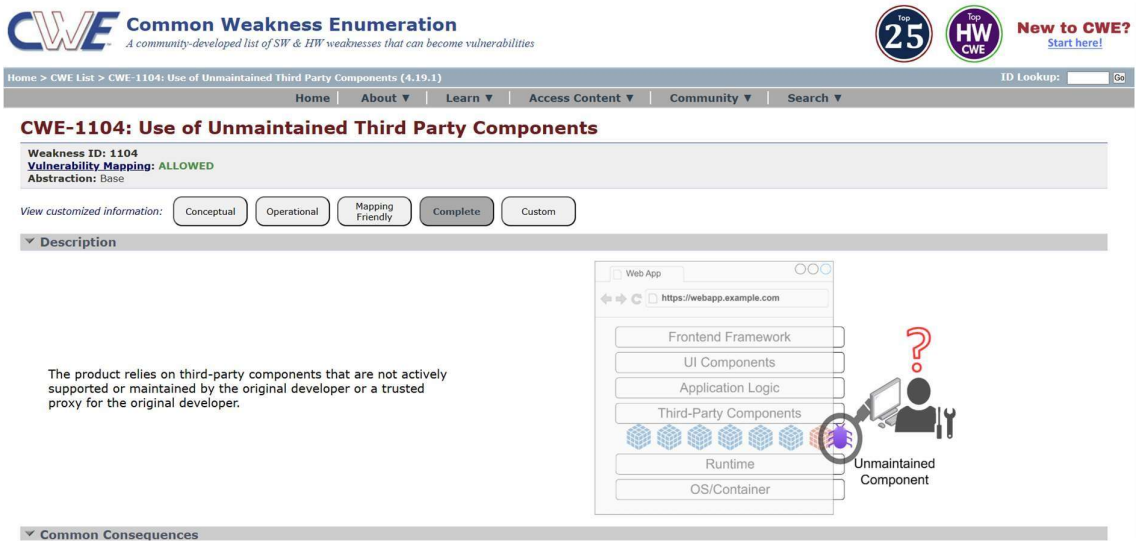
3) Vulnerability Name : Use of Unmaintained Third Party Components

CWE/CVE Number : CWE-1104

OWASP Category : A03:2025 Software Supply Chain Failures

Description: Software supply chain failures are breakdowns or other compromises in the process of building, distributing, or updating software. They are often caused by vulnerabilities or malicious changes in third-party code, tools, or other dependencies that the system relies on.

Business Impact: Unmaintained third-party components leave known vulnerabilities unpatched, exposing systems to exploits that cause data breaches, remote code execution, and full compromise. Businesses incur remediation costs, operational downtime, compliance violations (e.g., GDPR), and reputational damage from incidents like those in Log4j or printing systems.



Recommendation :

- Inventory Dependencies: Catalog all third-party components using tools like OWASP Dependency-Check or Snyk to iden fy versions and maintenance status.
- Upgrade or Replace: Promptly update to supported versions or switch to ac vely maintained alterna ves when patches are unavailable.

- Automate Monitoring: Implement So ware Bill of Materials (SBOM) and con nuous scanning for vulnerabili es and end-of-life no ces.
- Minimize Usage: Remove unused libraries and prefer vendored or forked versions from trusted proxies for cri cal unmaintained components.
- Apply Compensa ons: Use WAF, run me protec ons, and regular security audits as interim measures while planning migra ons.

This is stage 1 in the context of web applica on tes ng and security we take help from OWASP top 10 to understand them. The OWASP Top 10 is a widely recognized list of the most cri cal web applica on security risks. Understanding these risks is essen al for ensuring the security of web applica ons.

Stage 2

Title of the Project : Nessus Scan

Overview :

Nessus is a vulnerability scanner developed by Tenable, Inc. It is a remote scanner, meaning that it does not need to be installed on the target host to scan it. Nessus works by sending a variety of probes to the target host in order to identify vulnerabilities. These probes can include network traffic, operating system commands, and application requests.

Nessus uses a plugin-based architecture. Plugins are small pieces of code that are designed to identify specific vulnerabilities. There are over 1200 plugins available for Nessus, covering a wide range of vulnerabilities in operating systems, applications, and network devices.

When Nessus scans a host, it first uses a discovery plugin to identify the operating system and services running on the host. Once the host has been discovered, Nessus runs a series of plugins to test for vulnerabilities. For each vulnerability that Nessus finds, it provides

a detailed report that includes the severity of the vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications. It can also be used to scan specific ports and services. Nessus can be configured to run scans on a schedule or manually.

Here is a step-by-step explanation of how Nessus works:

1. Nessus connects to the target host using a variety of protocols, including TCP, UDP, and ICMP.
2. Nessus sends a series of probes to the target host in order to identify its operating system and services.
3. Nessus runs a series of plugins to test for vulnerabilities.
4. Nessus generates a report that includes the severity of each vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus is a valuable tool for security professionals who need to identify and remediate vulnerabilities in their networks. It is easy to use and provides comprehensive reports that can be used to prioritise remediation efforts.

Here are some of the benefits of using Nessus:

- Comprehensive vulnerability coverage: Nessus has over 1200 plugins available, covering a wide range of vulnerabilities in operating systems, applications, and network devices.

- Easy to use: Nessus has a user-friendly interface that makes it easy to configure and run scans.

- Comprehensive reporting: Nessus provides detailed reports that include the severity of each vulnerability,the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

- Scalability: Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications.

- Flexibility: Nessus can be configured to run scans on a schedule or manually. Nessus is a powerful tool that can be used to improve the security of any network. It is a valuable asset for any security professional.

Target website :- http://testfire.net/
Target ip address:- 65.61.137.117

List of vulnerability:-

S.no	Vulnerability name	severity	Plugins
1	TLS Version 1.0 Protocol Detec on	MEDIUM	04743
2	TLS Version 1.1 Protocol Deprecated	MEDIUM	57288
3	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam	LOW	83875

REPORT :-

1) Vulnerability Name: - 104743 - TLS Version 1.0 Protocol Detection Severity: - MEDIUM

Plugin: - 104743

Port: - 443

Description: - The remote service accepts connections encrypted using TLS 1.0. TLS 1.0 has a number of cryptographic design flaws. Modern implementations of TLS 1.0 mitigate these problems, but newer versions of TLS like 1.2 and 1.3 are designed against these flaws and should be used whenever possible.

As of March 31, 2020, Endpoints that aren't enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.

PCI DSS v3.2 requires that TLS 1.0 be disabled entirely by June 30, 2018, except for POS POI terminals (and the SSL/TLS termination points to which they connect) that can be verified as not being susceptible to any known exploits.

Solution: - Enable support for TLS 1.2 and 1.3, and disable support for TLS 1.0.

Business Impact: -Continued use of TLS 1.0's encryption, known for its inherent cryptographic flaws, exposes the organization to heightened security risks, increasing the likelihood of data breaches and cyberattacks. This vulnerability jeopardizes compliance with industry standards, specifically PCI DSS v3.2, which mandates the complete cessation of TLS 1.0 use. Non- compliance risks regulatory penalties and erodes customer trust. Moreover, endpoints that lack support for TLS 1.2 and higher will experience impaired functionality with major web browsers and vendors, potentially leading to lost business opportunities and damage to the organization's reputation. Addressing this vulnerability is imperative to mitigate these multifaceted risks and maintain a secure and trustworthy online presence

2) Vulnerability Name: - 157288 - TLS Version 1.1 Protocol Deprecated Severity: - MEDIUM

Plugin: - 157288

Port: - 443

Description: - The remote service accepts connections encrypted using TLS 1.1. TLS 1.1 lacks support for current and recommended cipher suites. Ciphers that support encryption before MAC computation, and authenticated encryption modes such as GCM cannot be used with TLS 1.1

As of March 31, 2020, Endpoints that are not enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.

Solution: - Enable support for TLS 1.2 and/or 1.3, and disable support for TLS 1.1.

Business Impact: -The continued use of TLS 1.1 with its lack of support for modern cipher suites and advanced encryption methods jeopardizes the organization's security posture, increasing vulnerability to cyber threats and potential data breaches. Additionally, endpoints not upgraded to support TLS 1.2 and higher will encounter compatibility issues with major web browsers and vendors, impacting user experience

and potentially leading to missed business opportunities. Swift remediation of this vulnerability is essential to mitigate security risks and ensure seamless interactions with web browsers and vendors, preserving the organization's reputation and operational efficiency.

3) Vulnerability Name: - 83875 - SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam) Severity: - LOW

Plugin: - 83875

Port: - 443

Description: - The remote host allows SSL/TLS connections with one or more DiffieHellman moduli less than or equal to 1024 bits. Through cryptanalysis, a third party may be able to find the shared secret in a short amount of time (depending on modulus size and attacker resources). This may allow an attacker to recover the plaintext or potentially violate the integrity of connections.

Solution: - Reconfigure the service to use a unique Diffie-Hellman moduli of 2048 bits or greater.

Business Impact: - Allowing SSL/TLS connections with weak Diffie-Hellman moduli raises security concerns. An attacker with sufficient resources and computing power could compromise the shared secret relatively quickly, potentially leading to the decryption of sensitive data or the violation of connection integrity. While the severity is low, the risk of data breaches and integrity compromise should not be underestimated, and it is essential to address this vulnerability to maintain data security and user trust.

Stage 3

Title: Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

Overview:

Identity :

Identity-based access ensures that only authenticated and authorized users can access the applications. The system verifies user credentials such as username, password, and multi-factor authentication before granting access. This helps in preventing unauth

Device posture :

Device posture checks whether the user's device is secure and compliant with security policies. It verifies antivirus, updates, encryption, and system health before allowing access. This ensures that only safe and trusted devices can connect to the applications.

Application risk :

Application risk analysis identifies sensitive and critical applications and protects them from unauthorized access. High-risk applications are given stronger security controls and limited access to reduce data breaches and cyber threats.

Context aware access :

Context-aware access combines iden ty, device posture, loca on, and applica on risk to provide secure access. It follows Zero Trust principles by allowing users to access only specific applica ons instead of the en re network, reducing a ack surface and lateral movement.

Conclusion :-

In conclusion, exploring the realm of AI for web security using IBM QRadar has been an insightful journey through various stages.

In Stage 1, understanding web application testing unveiled the critical importance of assessing vulnerabilities and ensuring the security of web-based systems. This foundational knowledge served as a cornerstone for comprehending the subsequent stages

Stage 2 delved into the intricacies of Nessus reports, emphasising the significance of detailed vulnerability assessments. Analysing these reports provided valuable insights into potential threats, enabling informed decision-making for robust security measures.

Stage 3 The replacement of the legacy VPN architecture with a cloud-native Zscaler Zero Trust solution marks a pivotal transformation in the organization's security posture. By shifting from a network-centric to an application-centric model, this project successfully eliminates the expanded attack surface inherent in publicly exposed VPN concentrators and completely eradicates the risk of lateral movement. The implementation of Zscaler Private Access (ZPA) ensures that users are connected only to specific applications after rigorous identity and device verification, rendering the internal network invisible. This modernization not only fortifies defenses against sophisticated cyber threats but also delivers a superior, low-latency experience for the hybrid workforce, establishing a future-ready security foundation..

Considering the future scope, Stage 1 illuminated the evolving landscape of web application testing. With advancements in AI, there is a promising avenue for more sophisticated testing methodologies, ensuring even higher levels of security for web applications.

Stage 2 highlighted the future trajectory of the testing process, indicating a shift towards more automation and integration of AI-driven tools. This evolution promises quicker, more accurate vulnerability assessments, enhancing overall cybersecurity postures

Stage 3 illuminated the future potential of Zero Trust Network Access (ZTNA) and Zscaler technologies. With AI integration and machine learning, these systems are poised to become more intelligent and adaptive, enabling real-time risk assessment based on user behavior and device posture. Enhanced automation in policy enforcement, predictive analytics for threat detection, and improved scalability are anticipated, empowering organizations to stay ahead of sophisticated cyber threats in an increasingly distributed world

In essence, the project not only provided a deep understanding of the current state zero trust using ZSCALER but also offered a glimpse into the exciting future of cybersecurity. Embracing these advancements will be crucial for organisations aiming to fortify their digital landscapes in the face of ever-evolving cyber threats.

Future Scope: -

Future of web application testing

The future of WAT is bright, as web applications become increasingly complex and sophisticated. Organizations are increasingly reliant on web applications to conduct business, and they need to be confident that their web applications are secure and reliable.

Here are some of the key trends that are expected to shape the future of WAT:

- Increased focus on security: Security is a top priority for all organizations, and WAT is essential for identifying and mitigating security vulnerabilities. In the future, we can expect to see even more emphasis on security testing, as web applications become increasingly targeted by cyberattacks.

- Rise of artificial intelligence (AI) and machine learning (ML): AI and ML are already being used in WAT, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.

- Shift to cloud-based testing: More and more organizations are moving their web applications to the cloud. This trend is driving the growth of cloud-based WAT platforms. Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness.

- Increased focus on user experience (UX) testing: UX testing is essential for ensuring that web applications are easy to use and meet the needs of users. In the future, we can expect to see more focus on UX testing, as organizations increasingly recognize the importance of providing a positive user experience.

Future scope of the testing process

The future scope of the testing process is bright, as software becomes increasingly complex and sophisticated. Organisations are increasingly reliant on software to conduct business, and they need to be confident that their software is high-quality and reliable.

Here are some of the key trends that are expected to shape the future of the testing process:

- Increased focus on continuous testing: Continuous testing is a methodology that involves testing software throughout the SDLC, from development to deployment. This helps to identify defects early and prevent them from causing problems later in the development process.

- Rise of AI and ML: AI and ML are already being used in the testing process, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.

- Shift to cloud-based testing: Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness. This is driving the growth of cloud-based testing platforms.

- Increased focus on testing automation: Testing automation is the use of software to execute test cases without human intervention. Testing automation can help to save time and resources, and it can also help to improve the quality and efficiency of testing.

Future scope of SOC / SEIM:-

While the current project successfully replaces the legacy VPN with Zscaler ZPA for remote access, the Zero Trust journey offers several avenues for future expansion and enhancement:

1. Workload-to-Workload Segmentation: Extend Zero Trust principles beyond user-to application connectivity to secure communication between internal workloads themselves. By deploying Zscaler Workload Segmentation, the university can enforce micro-segmentation within the data center and cloud environments, preventing lateral movement even between application tiers (e.g., web server to database server) without relying on network firewall rules.

2. Branch and Campus Transformation: Expand the Zscaler deployment to eliminate MPLS circuits and traditional hub-and-spoke networking. By routing all branch and campus internet traffic directly through Zscaler Internet Access (ZIA), the organization can reduce costs, improve performance, and apply consistent security policies to all users, regardless of their physical location.

3. OT and IoT Security Integration: Extend Zero Trust coverage to operational technology (OT) and Internet of Things (IoT) devices on campus, such as building management systems, security cameras, and lab equipment. Zscaler can provide visibility and segmentation for these often-unmanaged devices, ensuring they cannot be used as an entry point to attack core academic systems.

4. Advanced Data Loss Prevention (DLP): Enhance Zscaler deployment with advanced DLP capabilities to protect sensitive research data and student information. Future phases can include fingerprinting of sensitive documents, exact data matching (EDM) for structured data like student records, and integration with insider threat management tools to detect and block anomalous data exfiltration attempts.

5. AI-Driven Threat Hunting: Leverage Zscaler's AI-powered analytics and the integration with threat intelligence platforms like MISP to implement proactive threat hunting. Machine learning models can baseline normal user behavior and automatically flag anomalies—such as impossible travel or unusual data access patterns—for immediate investigation by the security operations center (SOC).

6. Privileged Remote Access for Vendors: Formalize and secure access for external vendors and contractors who require temporary access to specific systems for maintenance and support. Zscaler's privileged remote access capabilities can provide time-bound, session-recorded, and approval-based access to critical infrastructure without granting network-level privileges.

7. Integration with SOAR Platforms: Integrate Zscaler with security orchestration, automation, and response (SOAR) platforms to enable automated incident response workflows. For example, if Zscaler detects a compromised device, the SOAR platform can automatically trigger service desk tickets, isolate the device from the network, and reset the user's Active Directory credentials.

8. Continuous Compliance Automation: Utilize Zscaler logs and APIs to automate compliance reporting for regulations such as FERPA, GDPR, and HIPAA. Future development can include real-time compliance dashboards that demonstrate leastprivilege access, data protection controls, and audit readiness to regulators and internal auditors.

9. Zero Trust for Mergers and Acquisitions: As the university grows or partners with other institutions, Zscaler can provide a secure framework for rapidly integrating new users and applications. Zero Trust principles ensure that acquired entities can access specific resources without being placed on the internal network, maintaining security during transitional periods.

10. User Behavior Analytics (UBA): Implement advanced user behavior analytics to detect insider threats and compromised accounts. By analyzing patterns of application access, data transfer volumes, and login times, machine learning algorithms can identify subtle indicators of malicious activity that rule-based policies might miss.

Topics explored:

Data Collection and Aggregation, Standardization and Normalisation, Enrichment and Analysis, Sharing and Distribution, Integration with Security Tools, Customization and Flexibility, Automation and Orchestration, Community Involvement, Incident Response Support, Threat Intelligence Feeds, Soc and Siem

Tools explored :

Nmap, Metasploit, Nessus, Kali Linux, OWASP ZAP, Burp Suite

THE END